

Defining Secure Software Requirements

Overview

In this lab, you are going to define the secure software requirements for your project. This is a very important step before you come up with the design of your application. During this lab, we will walk around and understand how the team define the requirements for your application.

Outcomes

Upon completion of this session, you and your team should be able to

- Understand the secure software requirement
- Define the secure software requirement of your project

Tasks:

Work in teams, discuss with your teammates on the following, and write down the requirements:

1. Functional requirements of your application (During this lab, please limit the discussion to 2 – 3 major requirements)
2. Nonfunctional requirements of your application (During this lab, please limit the discussion to 2 – 3 major requirements)
3. Based on the functional and nonfunctional requirements, define the following security requirements, you may refer to SANS Securing Web Application Technologies [SWAT] Checklist for better understanding of the requirements:
<https://www.sans.org/cybersecurity-focus-areas/cloud-security/securing-web-application-technologies>
 - Confidentiality
 1. Define the data has to be protected in your application.
 2. Identify the confidentiality risks of those data.
 3. Define the requirements protect those data.

- Integrity

1. Discuss and identify the data that has to ensure the integrity in your application.
2. Identify the integrity risks of those data.
3. Define the requirements ensure the integrity of the data.

- Availability

1. Discuss how to ensure the availability of your application.
2. Identify the availability risks of your application.
3. Define the availability of your application.

- Authentication

1. Define the users of the application.
2. Identify the authentication risks of your application.
3. Define the requirement for your application authenticate the users.

- Authorization

1. Determine If there are difference type of users in your application.
2. Identify the authorization risks of your application.
3. Define the different permission in your application.

- Accountability

1. Define what information that required for accountability.
2. Identify the accountability risks of your application.
3. Define the requirement for your application to records user's activities.

Lab:

OWASP SecurityRAT: <https://owasp.org/www-project-securityrat/> is a tool to simplify security requirement management during development using automation approaches.

The core functionality of SecurityRAT (“Security Requirement Automation Tool”) can be described in the following steps:

1. You tell SecurityRAT what kind of a software artifact you’re going to develop / are running
2. SecurityRAT tells you which requirements you should fulfill.
3. You decide how you want to handle the desired requirements.
4. You persist the artifact state in an issue tracker and create tickets for the requirements where an explicit action is necessary
5. Throughout the continuous development of the particular artifact, you respect the rules defined in SecurityRAT and document relevant changes in requirement compliance whenever appropriate.

Installation:

Step 1: Follow Lab 1, Install docker and docker-compose: <https://www.docker.com>

Step 2: Clone the following github repository

(<https://github.com/SecurityRAT/SecurityRAT-dockercompose>), which contains the docker-compose script for SecurityRat:

```
git clone git@github.com:SecurityRAT/SecurityRAT-dockercompose.git
```

Step 3: In command prompt run:

```
docker-compose up --remove-orphans
```

Step 4: Update SecurityRat DB

```
docker exec securityrat-mariadb sh -c './var/dumpRequirements.sh'
```

Note: There may be a Windows-style line endings (CRLF) error which break execution inside a Linux-based container. To fix this:

```
docker exec -it securityrat-mariadb /bin/sh  
cd /var/  
sed -i 's/\r$//' dumpRequirements.sh
```

Step 5: once the image has started, navigate to <http://localhost:9002>

Step 6: authenticate with one of the default users admin/admin or user/user

Step 7: start playing around, the detail video demo and document located via: <https://securityrat.github.io>

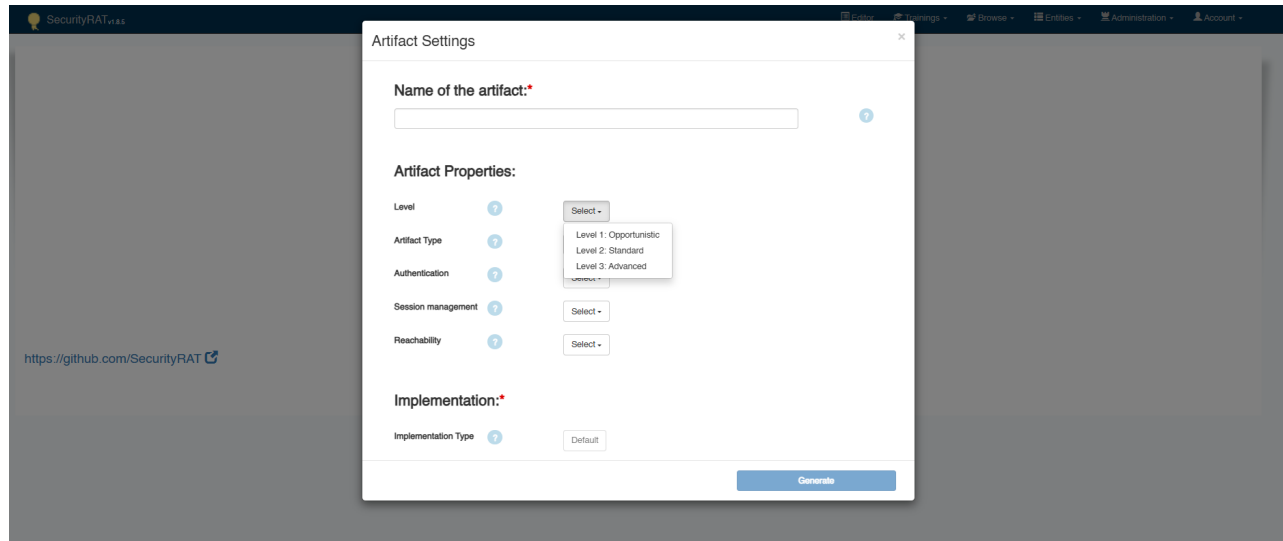


Figure 1: Create Artifact

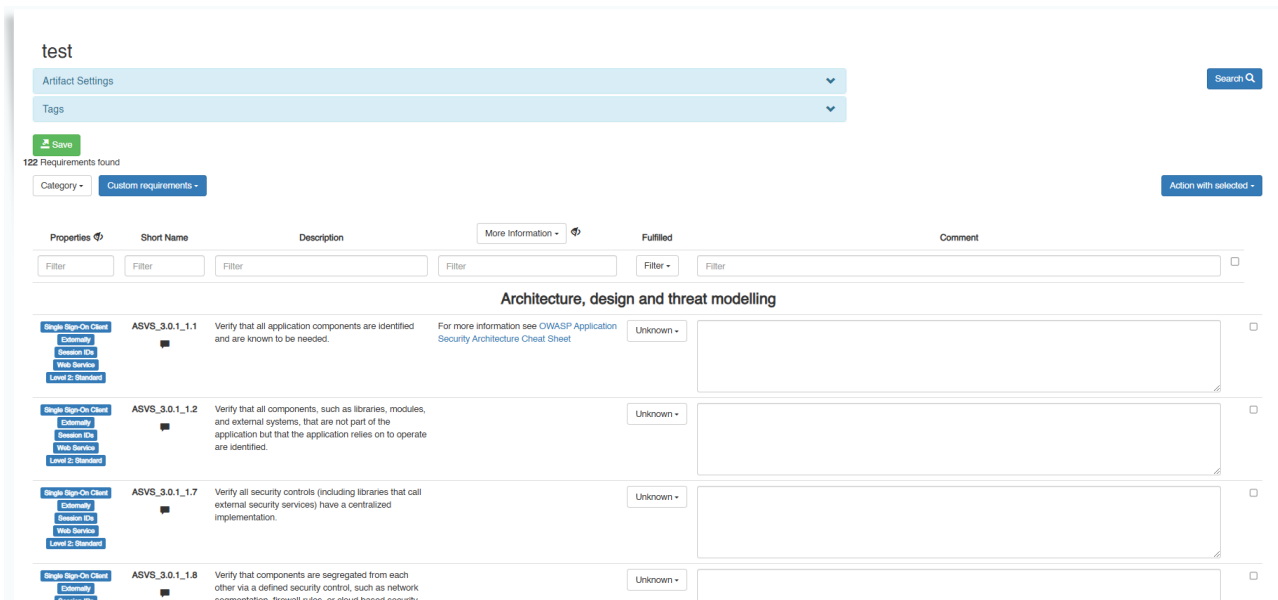


Figure 2: The requirement to consider after generation

Step 8: Clean up. After stopping the app, run `docker-compose down` to remove the created containers.

END OF DOCUMENT